identity attributes, device posture, operational signals like on-call status, and environmental context. The outcome of that assessment is then enforced by the policy enforcement point (PEP) at the target resource. As we saw in Chapter 10, ACME had already implemented several deployment strategies for their policy decision points (PDPs) and PEPs; a zero-trust security architecture did not require replacing them. Any of these patterns could participate, as long as they evaluated a consistent set of policies.

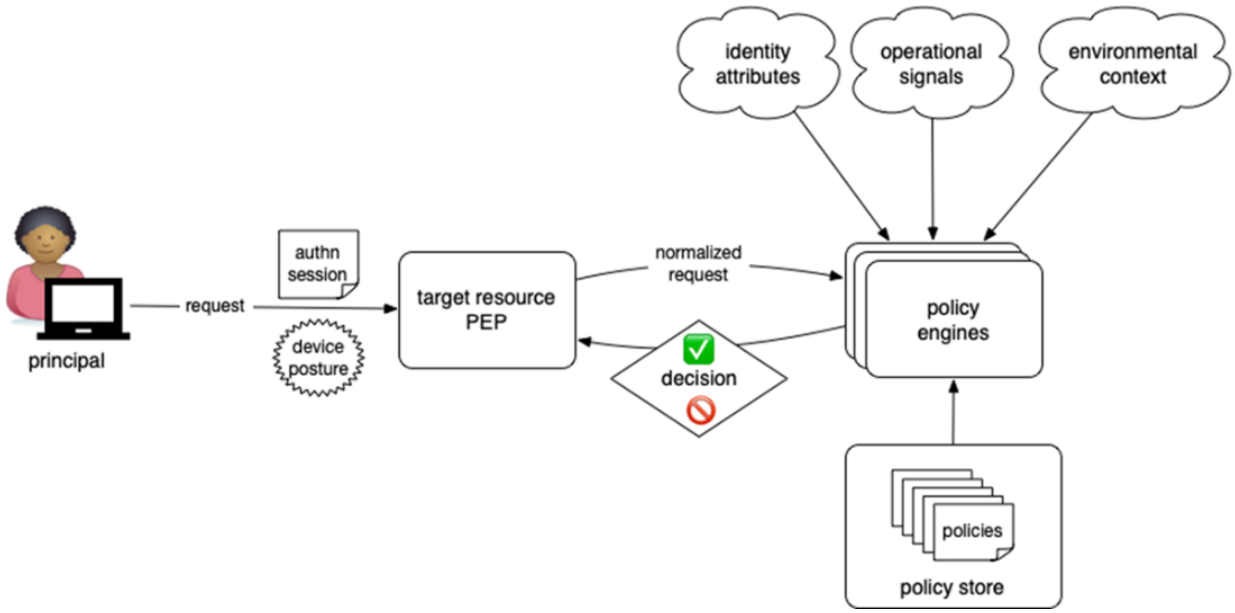


Figure 15.2 Zero Trust is enforced through continuous authorization. Every access request is evaluated by a policy engine. Identity attributes, device posture, operational signals, and environmental context further influence the decision. The result is enforced locally by the PEP guarding the target resource.

What changed for ACME was who authored those policies and what they expressed. Up to this point, most of ACME's use of policy-based access control had been driven by application teams writing service-specific policies or by engineering teams creating policies for deployment tools and internal APIs. Those policies governed how a particular application or system behaved. In a zero-trust security architecture, a new category of policy emerged: foundational security policies managed by the security and identity teams.

These foundational policies apply broadly across the entire organization. Instead of controlling just one application or workflow, they set requirements for the entire enterprise. They included minimum device